INFRAESTRUTURA DE E-MAIL / DEFESA DE DOMÍNIOS

MANUAL DE INVESTIGAÇÃO DE POLÍTICAS SPF

Da conexão SMTP ao diagnóstico de DNS, include, redirect, erros de avaliação, alinhamento DMARC, relatórios agregados e proteção de domínios que não enviam e-mail.

REFERÊNCIA PRÁTICA

Checklists · comandos Linux · fluxos de avaliação · incidentes · exercícios com solução · laboratório reproduzível

DESTINADO A

Administração de sistemas · suporte · redes · NOC · segurança de e-mail

Edição de consulta • Outubro de 2026 • Base normativa: RFC 7208, RFC 9989, RFC 9990, RFC 8601, RFC 8617, RFC 7505 e RFC 5321

Exemplos com domínios .example e blocos IP reservados para documentação. Nenhum procedimento exige alteração em produção.

REVISÃO 4 / 28 DE OUTUBRO DE 2026 / 43 PÁGINAS

Como utilizar este manual

Este material é um guia de investigação operacional, não uma simples lista de mecanismos. A metodologia parte de evidências coletadas em SMTP e DNS e separa três perguntas: **qual identidade foi testada**, **por que o SPF chegou ao resultado observado** e **qual política de recebimento foi aplicada**.

> **ROTA CURTA PARA INCIDENTES** Comece pelo capítulo 2, use o playbook do capítulo 13, consulte as tabelas de resultados do capítulo 8 e preencha o modelo de relatório do Apêndice A.

Escopo: investigação de SPF em envio direto, serviços terceiros, encaminhamento, IPv4/IPv6, falhas DNS e integração com DMARC e ARC. A validação completa requer um avaliador SPF; `dig`, isoladamente, apenas consulta registros.

Organização

Parte	Conteúdo
Fundamentos — cap. 1 a 8	Identidades SMTP, algoritmo de avaliação, coleta DNS, mecanismos, include, redirect, limites e resultados.
Autenticação de domínio — cap. 9 a 12	Alinhamento DMARC relaxed/strict, falsos diagnósticos, encaminhamento com SRS e ARC, domínios que não enviam e-mail.
Operação — cap. 13 a 16	Playbook de produção, estudos de caso, mudanças seguras e exercícios sem gabarito.
Prática ampliada — cap. 17 a 26	Incidente completo, coleta auditável, cabeçalhos, laboratório pySPF, contagem de consultas, macros, DNS real, estratégias para o limite de 10 e relatórios DMARC agregados.
Apêndices — A a E	Modelo de relatório, gabarito comentado, referência rápida, fontes oficiais e registro de revisões.

O que mudou na Revisão 4

- Nova seção 8.3: o cabeçalho **Received-SPF**, com exemplos gerados pelo próprio avaliador.
- Novo capítulo 25: **estratégias para não estourar o limite de 10** (pior caso, subdomínios de envio, CNAME de retorno, flattening, tamanho do registro).
- Novo capítulo 26: **relatórios DMARC agregados** (RFC 9990), com script de resumo testado e anexado.
- Novos Labs 11 e 12; laboratório pySPF ampliado para dez testes.

As mudanças da Revisão 3 (alinhamento relaxed/strict, SRS e ARC, domínios que não enviam e-mail, RFC 9989) estão no Apêndice E.

Laboratórios testados com pySPF 2.0.14, defusedxml 0.7.1 e Python 3.13. Os dois scripts estão anexados internamente a este PDF (`lab_spf.py` e `dmarc_resumo.py`).

Sumário

FUNDAMENTOS

01 Anatomia de um incidente SPF 04
02 Método de avaliação: do IP ao resultado 05
03 Coleta de evidências DNS em Linux 05
04 Ler políticas sem confundir DNS e SPF 07
05 Investigação de include: o ponto de maior atenção 07
06 Redirect, prioridade e erros de sintaxe 08
07 Limites DNS e diagnóstico de permerror 09
08 Resultados SPF e decisões SMTP 10

AUTENTICAÇÃO DE DOMÍNIO

09 Alinhamento DMARC: relaxed e strict 12
10 Cenários que geram falsos diagnósticos 13
11 Encaminhamento: SRS e ARC 14
12 Domínios que não enviam e-mail 15

OPERAÇÃO

13 Playbook de investigação em produção 17
14 Estudos de caso comentados 18
15 Mudanças seguras, validação e rollback 19
16 Laboratórios de investigação 20

PRÁTICA AMPLIADA

17 Incidente completo: do alerta à causa raiz 23
18 Coleta DNS que pode ser auditada 23
19 Cabeçalhos, confiança e conclusão 25
20 Laboratório: preparação e resultados 25
21 Código completo do laboratório 27
22 Contagem de consultas sem atalhos 29
23 Macros, exists e armadilhas de sintaxe 30
24 Avaliação com DNS real e mudanças seguras 30
25 Estratégias para não estourar o limite de 10 32
26 Relatórios DMARC agregados na investigação 34

APÊNDICES

A Modelo de relatório de incidente 39
B Gabarito comentado 40
C Referência rápida de investigação 41
D Fontes oficiais e leitura dirigida 42
E Registro de revisões 43

01 Anatomia de um incidente SPF

SPF verifica a autorização do IP do cliente SMTP para uma identidade SMTP avaliada: usualmente o domínio do MAIL FROM (`RFC5321.MailFrom`) ou o nome HELO/EHLO. Não comprova a identidade da pessoa, não assina o corpo e não valida diretamente o `From:` exibido ao usuário.

```
S: 220 mx.destino.example ESMTP
C: EHLO smtp.origem.example
S: 250 mx.destino.example
C: MAIL FROM:<retornos@empresa.example>
S: 250 2.1.0 Ok
C: RCPT TO:<alvo@destino.example>
S: 250 2.1.5 Ok
C: DATA
S: 354 End data with <CRLF>.<CRLF>
C: From: Financeiro <financeiro@empresa.example>
C: Subject: Fatura
C: ...corpo da mensagem...
```

Elemento	Uso na investigação
IP do cliente SMTP	Endereço efetivo da conexão recebida; pode ser o IP de um relay ou NAT.
MAIL FROM	Endereço do envelope; sua parte de domínio é a referência usual para SPF.
HELO / EHLO	Identidade adicional que também pode ter SPF; particularmente importante com MAIL FROM vazio.
From:	Cabeçalho da mensagem. Usado para alinhamento DMARC; não substitui o MAIL FROM.
RCPT TO	Destinatário do envelope; não determina qual domínio SPF verificar.
Return-Path:	Indício do envelope após a entrega; interpretar no contexto dos saltos e de quem inseriu o cabeçalho.

> **ERRO RECORRENTE** Não confunda `10 mail.empresa.example` de um registro MX com um endereço IP: 10 é a prioridade do MX e `mail.empresa.example` é um nome de host.

1.1 MAIL FROM vazio e a identidade HELO

Mensagens de notificação de falha de entrega (DSN) podem usar `MAIL FROM:<>`. Nesse caso, para a identidade MAIL FROM, o SPF constrói uma identidade equivalente a `postmaster@<domínio do HELO>`. O verificador também pode avaliar o HELO separadamente. Registre os resultados por identidade nos logs de auditoria.

```
EHLO bounce.mail.example
MAIL FROM:<>
# Identidade de fallback para check_host():
# postmaster@bounce.mail.example
```

02 Método de avaliação: do IP ao resultado

01 CAPTURAR — IP da conexão, MAIL FROM · HELO → **02 CONSULTAR** — TXT do domínio efetivamente avaliado → **03 AVALIAR** — Mecanismos em ordem include · redirect · limites → **04 CONCLUIR** — Resultado SPF ≠ ação do receptor

Use sempre o IP do cliente SMTP, não o IP de um servidor mencionado em um cabeçalho. Resultado SPF e ação do receptor são registros distintos.

01 Fixe o IP da conexão, a identidade testada e a hora do incidente; não tente inferir o IP a partir do campo `From:` visível.

02 Selecione o domínio efetivamente avaliado; consulte seus registros TXT e identifique um único SPF válido iniciado por `v=spf1`.

03 Valide a sintaxe e percorra os mecanismos na ordem em que aparecem; a primeira correspondência encerra a avaliação.

04 Quando houver include ou redirect, consulte a política indicada e registre o caminho de avaliação, mantendo o mesmo IP e o mesmo remetente.

05 Considere limites de DNS, erros de resolução e códigos especiais. Não transforme automaticamente problemas de DNS em Fail.

06 Registre o resultado SPF e, em separado, a decisão do servidor receptor: aceitar, rejeitar, quarentenar ou aplicar outras verificações.

2.1 Os sete resultados

Resultado	O que significa	Próxima ação
pass	O IP foi autorizado pela política avaliada.	Verificar alinhamento DMARC e outros controles; não implica mensagem segura.
fail	O domínio afirma que o IP não está autorizado.	Verificar IP, NAT, serviço terceiro, encaminhamento e `-all`.
softfail	O domínio sinaliza provável ausência de autorização.	Revisar `~all` e o caminho de envio; não tratar como autorização.
neutral	A política não afirma nem nega autorização.	Procurar `?all` ou ausência de correspondência sem redirect.
none	Não há política SPF aplicável ou o domínio não é elegível.	Confirmar nome consultado, publicação e DNS.
temperror	Falha temporária durante a avaliação (timeout, SERVFAIL).	Repetir a consulta, revisar servidores DNS e horário da ocorrência.
permerror	Política inválida ou limite de processamento excedido.	Auditar sintaxe, duplicidade, include/redirect e limites.

03 Coleta de evidências DNS em Linux

Execute os comandos a partir de um host de investigação. Registre data, hora, resolvedor, domínio consultado e resposta completa. Os exemplos usam domínios reservados; substitua pelos domínios sob sua responsabilidade.

```
# Inspecionar TXT com TTL, cabeçalho da resposta, tempo e servidor
dig TXT empresa.example +noall +answer +comments +stats

# Exibir TXT de modo compacto
dig +short TXT empresa.example

# Checar endereços e hosts do MX
dig A empresa.example +short
dig AAAA empresa.example +short
dig MX empresa.example +noall +answer
dig A mail.empresa.example +short

# Comparar respostas entre resolvedores
dig @1.1.1.1 TXT empresa.example +noall +answer
dig @8.8.8.8 TXT empresa.example +noall +answer

# Consultar o TXT de um provedor incluído
dig TXT _spf.provedor.example +noall +answer

# Consultar a política DMARC do domínio do From
dig TXT _dmarc.empresa.example +short
```

3.1 O que observar nas respostas

- **Nome consultado:** o SPF de um MAIL FROM em `subdominio.empresa.example` deve ser investigado naquele nome, não automaticamente no domínio organizacional.
- **Quantidade de TXT iniciados por `v=spf1`** no mesmo nome: dois ou mais registros SPF selecionados produzem permerror.
- **TTL e diferenças entre resolvedores:** podem explicar divergências temporárias após alterações.
- **CNAME, NXDOMAIN, SERVFAIL, timeout e respostas vazias:** cada situação deve ser analisada segundo as regras da RFC 7208.
- **TXT longos** podem aparecer como várias strings em uma mesma resposta; isso não significa vários registros SPF.

> **IMPORTANTE** Uma consulta `dig TXT` demonstra a publicação DNS; não reproduz sozinha o algoritmo `check_host()`, não contabiliza as consultas recursivas nem mostra a política aplicada pelo gateway.

3.2 Trilha de evidências

Evidência	Exemplo anotado
Hora e fuso	2026-10-28 13:15 -03:00
IP SMTP	198.51.100.45
Identidade SPF	`smtp.mailfrom=empresa.example`
DNS consultado	TXT empresa.example
Registro encontrado	`v=spf1 ip4:192.0.2.10 include:_spf.provedor.example -all`
Resultado	`spf=pass` ou `spf=fail`; anotar também a etapa de decisão
Origem da evidência	Log do gateway ou cabeçalho inserido pelo domínio de confiança

04 Ler políticas sem confundir DNS e SPF

Termo SPF	Significado operacional	Custo de lookup
ip4 / ip6	Compara o IP com um endereço ou prefixo CIDR.	Não conta.
a	Consulta A (conexão IPv4) **ou** AAAA (conexão IPv6) do domínio avaliado ou indicado.	Conta.
mx	Consulta o MX do domínio e, em seguida, A ou AAAA dos hosts MX, conforme a versão do IP.	Conta; há limite adicional.
include	Avalia recursivamente uma política externa; corresponde se ela retornar pass.	Conta, inclusive aninhados.
exists	Consulta A para um nome expandido; corresponde se houver resposta.	Conta.
ptr	Usa DNS reverso validado; mecanismo desaconselhado pela RFC.	Conta; consultas adicionais.
all	Sempre corresponde; costuma encerrar a política com `-all` ou `~all`.	Não conta.
redirect=	Transfere a avaliação quando nenhum mecanismo corresponde.	Conta se avaliado.
exp=	Explicação opcional para Fail; não é autorização.	Não entra nos 10 termos.

4.1 Qualificadores

Prefixo	Resultado quando corresponde	Interpretação
+	pass	Autorizado; é o qualificador implícito.
-	fail	Explicitamente não autorizado.
~	softfail	Provável não autorização, sem afirmar Fail definitivo.
?	neutral	Sem afirmação de autorização.

```
v=spf1 ip4:192.0.2.10 ip4:192.0.2.20 -all
v=spf1 ip4:192.0.2.0/24 ~all
v=spf1 a mx include:_spf.fornecedor.example -all
```

4.2 CIDR: uma diferença decisiva

`ip4:198.51.100.0/25` corresponde a 128 endereços, de 198.51.100.0 a 198.51.100.127. `ip4:198.51.100.0/24` corresponde a 256, de .0 a .255. SPF usa correspondência matemática do prefixo, inclusive nos endereços de borda; não confunda com a contagem de hosts atribuíveis em uma LAN.

05 Investigação de include: o ponto de maior atenção

O nome `include` induz ao erro. Ele não copia o texto de outro registro para dentro do SPF principal: solicita uma avaliação recursiva de `check_host()` para o domínio indicado, mantendo o IP e a identidade do remetente.

```
# Política do domínio do MAIL FROM
empresa.example.     TXT "v=spf1 ip4:192.0.2.10 include:_spf.envio.example -all"
# Política externa
_spf.envio.example.  TXT "v=spf1 ip4:198.51.100.0/25 -all"
```

5.1 Tabela decisiva: retorno do include

Avaliação externa	Efeito do include (sem qualificador explícito)
pass	Corresponde; o SPF principal retorna pass.
fail	Não corresponde; o principal segue para o próximo mecanismo.
softfail	Não corresponde; o principal segue.
neutral	Não corresponde; o principal segue.
temperror	Propaga temperror.
permerror	Propaga permerror.
none	Produz permerror no mecanismo include.

REGRA DE OURO Um `-all` no registro incluído não cancela a política principal. Ele faz o include não corresponder, e o algoritmo prossegue até o próximo mecanismo do registro principal.

5.2 Três trilhas passo a passo

IP testado	Trilha de avaliação	Resultado
192.0.2.10	Corresponde ao ip4 inicial; o include nem é executado.	pass
198.51.100.45	Não corresponde ao ip4 local; o include passa pelo /25.	pass
203.0.113.90	ip4 local não corresponde; o externo chega ao -all e falha; o include não corresponde; o -all principal encerra.	fail

5.3 Como investigar includes aninhados

01 Anote a política do domínio principal exatamente como recebida do DNS.

02 Localize o primeiro include efetivamente avaliado e consulte seu TXT.

03 Identifique, dentro do registro externo, os termos avaliados até a correspondência ou o erro.

04 Retorne ao registro chamador com o resultado externo; continue se não houve correspondência.

05 Mantenha um contador global dos termos de consulta DNS avaliados durante todo o caminho.

06 Conclua com o resultado do domínio principal, não com o resultado isolado de algum include.

06 Redirect, prioridade e erros de sintaxe

`redirect=` compartilha uma política inteira com outro domínio quando não houve correspondência na política local. Ao contrário do include, o resultado da avaliação redirecionada é devolvido como resultado da política principal.

```
empresa.example.       TXT "v=spf1 ip4:192.0.2.10 redirect=_spf.central.example"
_spf.central.example.  TXT "v=spf1 ip4:198.51.100.10 -all"
```

- Para 192.0.2.10, o ip4 local produz pass e o redirect não é executado.
- Para 198.51.100.10, não há correspondência local e o redirect retorna pass.
- Para 203.0.113.50, o redirect retorna fail por causa do `-all` externo.
- Se existir qualquer mecanismo `all` no registro principal, o redirect é ignorado, independentemente da posição.
- Se o redirect apontar para um domínio sem SPF aplicável, o resultado é permerror.

6.1 Erros estruturais que merecem triagem

Evidência	Efeito típico	Correção
Dois TXT `v=spf1` no mesmo nome	permerror	Publicar uma única política consolidada.
`v=spf1` repetido na mesma string	Sintaxe inválida / permerror	Remover a duplicação.
`ip4: 192.0.2.10` com espaço	Termo inválido	Usar `ip4:192.0.2.10`.
include para nome sem SPF	permerror	Conferir o nome e a política publicada.
`all` antes de outros mecanismos	Mecanismos posteriores ignorados	Reorganizar e eliminar termos mortos.
include/redirect circular	Avaliação problemática e limites	Remover o ciclo; revisar dependências.

07 Limites DNS e diagnóstico de permerror

A RFC 7208 define um limite global de **10 termos** que exigem consultas DNS durante a avaliação: `include`, `a`, `mx`, `ptr`, `exists` e `redirect`. O limite considera os termos efetivamente avaliados, inclusive dentro de includes e redirects. Excedê-lo produz permerror. `ip4`, `ip6` e `all` não entram na contagem.

> **NÃO CONFUNDIR** O limite de 10 termos não equivale a contar linhas retornadas por `dig`, consultas em cache, registros A ou pacotes DNS. Existem ainda limites específicos para MX e PTR (capítulo 22).

7.1 Consultas vazias (void lookups)

A RFC recomenda limitar a **dois** os void lookups: respostas NXDOMAIN ou NOERROR com zero registros. O limite pode ser configurável; excedê-lo produz permerror. Registre nome, tipo, status e contagem de respostas de cada consulta vazia.

7.2 Como contar sem adivinhar

```
v=spf1 include:_spf.a.example include:_spf.b.example -all
# Se o primeiro include retornar pass: o segundo não é avaliado.
# Se o primeiro não corresponder: o segundo é avaliado e soma termos.
# Includes aninhados compartilham o mesmo limite global.
```

7.3 Fluxo de triagem para permerror

01 Verifique se há exatamente um TXT SPF aplicável e se a sintaxe completa é válida.

02 Liste os termos de lookup na ordem em que seriam avaliados para o IP e o remetente em questão.

03 Expanda cada include/redirect visitado, registrando o caminho real e os resultados retornados.

04 Considere os termos dentro das políticas de terceiros e os limites específicos de mx/ptr.

05 Procure void lookups, redirect para domínio sem SPF e problemas de macros.

06 Reduza termos ou simplifique a arquitetura preservando o conjunto real de IPs autorizados; reteste com avaliador SPF completo. As técnicas estão no capítulo 25.

08 Resultados SPF e decisões SMTP

Um resultado SPF não é, por si só, uma ordem de entrega. O gateway aplica política local, filtros antispam, DMARC, reputação e outros controles. Um SPF Fail pode motivar rejeição durante a sessão SMTP, mas a rejeição não é obrigatória pelo protocolo.

```
Authentication-Results: mx.destino.example;
 spf=fail smtp.mailfrom=empresa.example;
 dkim=pass header.d=empresa.example;
 dmarc=pass header.from=empresa.example
```

Esse conjunto é possível: o SPF falhou, enquanto o DKIM passou e estava alinhado com o From visível, permitindo DMARC Pass. Separe sempre autenticação de disposição final.

8.1 Evidência em cabeçalhos

- Localize o `Authentication-Results` inserido pelo gateway na fronteira de confiança da organização. Cabeçalhos antigos ou forjados enganam.
- Identifique `spf=...` e `smtp.mailfrom=...` ou `smtp.helo=...`, verificando qual identidade foi autenticada.
- Compare o domínio autenticado com o `header.from` do DMARC e com os resultados de DKIM.
- Use `Received:` para reconstruir os saltos, sem presumir que todas as linhas são confiáveis.

8.2 SPF e alinhamento DMARC

Situação	SPF	Alinhamento SPF / efeito no DMARC
MAIL FROM `empresa.example`; From `empresa.example`	pass	Alinhado em strict e relaxed; o SPF sustenta DMARC Pass.
MAIL FROM `retorno.empresa.example`; From `empresa.example`	pass	Alinhado somente em relaxed (`aspf=r`, o padrão). Ver capítulo 9.
MAIL FROM `bounce.provedor.example`; From `empresa.example`	pass	Não alinhado; o pass pertence ao domínio do provedor. DMARC depende de DKIM alinhado.
SPF fail; DKIM pass com `d=empresa.example`; From `empresa.example`	fail	SPF não contribui; DMARC ainda passa via DKIM alinhado.

8.3 O cabeçalho Received-SPF NOVO

Além do `Authentication-Results`, muitos receptores registram o resultado no cabeçalho `Received-SPF`, definido pela RFC 7208 (seção 9.1). É o caso típico do Postfix com um serviço de política SPF, como o `postfix-policyd-spf-python`. Ele trata apenas de SPF, mas traz detalhes que o Authentication-Results normalmente omite, em especial o **mecanismo que decidiu** a avaliação.

Os dois exemplos abaixo foram gerados pelo próprio pySPF no laboratório (capítulos 20 e 21), com a política corrigida do incidente do capítulo 17:

```
Received-SPF: Pass
  (mx.destino.example: domain of empresa.example designates 198.51.100.10 as permitted sender)
  client-ip=198.51.100.10;
  envelope-from="alertas@empresa.example";
  helo=smtp.empresa.example;
  receiver=mx.destino.example;
  mechanism="include:_spf.parceiro.example";
  identity=mailfrom

Received-SPF: Fail
  (mx.destino.example: domain of empresa.example does not designate 203.0.113.99 as permitted sender)
  client-ip=203.0.113.99;
  envelope-from="alertas@empresa.example";
  helo=smtp.empresa.example;
  receiver=mx.destino.example;
  mechanism=-all;
  identity=mailfrom
```

Campo	Uso na investigação
resultado	Primeira palavra: pass, fail, softfail, neutral, none, temperror ou permerror.
comentário	Texto livre entre parênteses; identifica o receptor e resume a decisão. Não é padronizado: não automatize em cima dele.
client-ip	IP da conexão SMTP efetivamente avaliado. Compare com o IP que você esperava (NAT, relay).
envelope-from	MAIL FROM recebido; em DSN aparece vazio ou com `postmaster@` do HELO.
helo	Nome apresentado no EHLO/HELO.
identity	`mailfrom` ou `helo`: qual identidade este cabeçalho descreve. Pode haver um cabeçalho por identidade.
mechanism	Termo que encerrou a avaliação. Um `-all` indica que nada correspondeu; um `include:` indica qual ramo autorizou. Mostra diretamente a trilha dos capítulos 5 e 17.
problem	Previsto pela RFC para temperror/permerror, descrevendo o erro (sintaxe, DNS, limite). Alguns avaliadores, como o pySPF, colocam essa descrição no comentário em vez do campo. É o ponto de partida do fluxo 7.3.
receiver	Quem avaliou. Deve ser um host da sua fronteira de confiança.

> **CONFIANÇA** O `Received-SPF` é inserido no topo da mensagem por quem avaliou. Um remetente pode incluir cabeçalhos `Received-SPF` falsos na própria mensagem; eles aparecem **abaixo** do cabeçalho legítimo. Considere apenas o inserido pelo seu MTA, logo acima ou junto do `Received:` que registra a entrada na sua infraestrutura. Alguns gateways removem os recebidos de fora; confirme o comportamento do seu.

```
# Em uma mensagem salva (.eml), na ordem em que aparecem (o primeiro é o mais recente)
grep -n -i -A8 '^Received-SPF:' mensagem.eml

# No log do Postfix com serviço de política SPF (nome do processo varia)
sudo grep -i 'policyd-spf' /var/log/mail.log | tail -n 40
```

09 Alinhamento DMARC: relaxed e strict NOVO

DMARC passa quando **pelo menos um** dos métodos (SPF ou DKIM) passa **e** está alinhado com o domínio do `From:` visível. O alinhamento tem dois modos, configurados separadamente na política DMARC do domínio do From:

Modo	Tag	Regra
relaxed	`aspf=r` / `adkim=r`	O domínio autenticado e o domínio do From compartilham o mesmo **domínio organizacional**. É o padrão quando a tag é omitida.
strict	`aspf=s` / `adkim=s`	O domínio autenticado é **idêntico** ao domínio do From.

`aspf` controla o alinhamento do SPF (domínio do MAIL FROM); `adkim`, o do DKIM (tag `d=` da assinatura). Um domínio pode, por exemplo, aceitar SPF relaxed e exigir DKIM strict.

9.1 Exemplos para From: avisos@empresa.example

Domínio autenticado pelo SPF (MAIL FROM)	relaxed	strict
`empresa.example`	alinhado	alinhado
`retorno.empresa.example`	alinhado	não alinhado
`a.b.empresa.example`	alinhado	não alinhado
`fornecedor.example`	não alinhado	não alinhado
`empresa.example.fornecedor.example`	não alinhado	não alinhado

> **ARMADILHA** O último caso começa com `empresa.example`, mas seu domínio organizacional é `fornecedor.example`. Alinhamento compara domínios organizacionais, não prefixos de texto.

9.2 Como o domínio organizacional é descoberto

A RFC 7489 determinava o domínio organizacional com uma lista de sufixos públicos (Public Suffix List). A **RFC 9989** (maio de 2026), que torna obsoletas a RFC 7489 e a RFC 9091, substitui a lista por um **DNS Tree Walk**: o avaliador consulta registros `_dmarc` em nomes progressivamente mais curtos e usa as tags `psd=` e a presença de registros para decidir onde fica o limite organizacional.

- Na maioria dos domínios comuns os dois métodos chegam à mesma resposta.
- Durante a transição, receptores diferentes podem usar métodos diferentes. Em um caso de borda, registre qual avaliador e qual método foram usados antes de concluir.
- Os registros continuam usando `v=DMARC1`. A RFC 9989 remove a tag `pct` e introduz `t` (modo de teste), `np` (política para subdomínios inexistentes) e `psd`.

9.3 Investigação prática

```
dig TXT _dmarc.empresa.example +short
# "v=DMARC1; p=quarantine; aspf=r; adkim=s; rua=mailto:dmarc@empresa.example"
# aspf=r  -> SPF alinha por domínio organizacional
# adkim=s -> DKIM só alinha com d= idêntico ao From
```

01 Extraia o domínio do `From:` (`header.from`) e consulte `_dmarc` desse nome; se não existir, siga o método de descoberta do receptor.

02 Anote `p`, `sp`, `np`, `aspf`, `adkim` e `t`. Tags ausentes assumem o padrão (`r` para alinhamento).

03 Compare `smtp.mailfrom` e `header.d` com o domínio do From usando o modo de cada método.

04 Conclua: DMARC Pass exige ao menos um método com **pass e alinhado**.

> **CONSEQUÊNCIA DE SEGURANÇA** Com `aspf=r`, qualquer subdomínio que obtenha SPF Pass alinha com o domínio principal. Um subdomínio esquecido com SPF permissivo (por exemplo, `+all` ou um include de serviço compartilhado) vira um caminho de spoofing do From principal. A higiene de subdomínios do capítulo 12 é parte da defesa DMARC.

10 Cenários que geram falsos diagnósticos

10.1 Encaminhamento

No encaminhamento convencional, o destinatário final verifica o IP do servidor intermediário, e não o da origem inicial. Se o MAIL FROM original for preservado, o SPF pode falhar mesmo com a política correta. O capítulo 11 detalha SRS e ARC.

10.2 Serviços de envio terceirizados

Confirme se o fornecedor realmente usa o seu domínio no MAIL FROM, identifique seus ranges ou o include oficial e documente a relação contratual. Um SPF Pass para o domínio de bounce do fornecedor não garante alinhamento com o From da empresa; um domínio de retorno personalizado (subdomínio seu) alinha em modo relaxed.

10.3 NAT, relays e IPs privados

O receptor usa o IP da conexão que chega ao servidor. Em redes corporativas, esse IP costuma ser o IP público de saída do NAT ou relay, não o endereço RFC 1918 do host de aplicação. Verifique firewall, relay e gateway de e-mail antes de editar o DNS.

10.4 IPv6 e infraestrutura mista

Um `ip4` não autoriza IPv6. Se o MTA sai por IPv6, verifique a existência de `ip6` e confirme o IP efetivo da sessão. Não corrija uma falha de IPv6 acrescentando apenas IPv4.

10.5 HELO, DSN e bounce

Ao receber `MAIL FROM:<>`, confira a identidade HELO e sua política. Um servidor pode obter pass para HELO e outro resultado para MAIL FROM em outras transações. O registro precisa explicitar qual identidade foi validada.

11 Encaminhamento: SRS e ARC NOVO

Encaminhamentos e listas de discussão quebram a autenticação de formas diferentes. SPF falha porque o IP muda; DKIM falha quando o intermediário altera assunto, corpo ou rodapé. Duas técnicas atacam problemas distintos:

Técnica	O que faz	O que não faz
SRS	O encaminhador reescreve o MAIL FROM para um endereço do seu próprio domínio, permitindo SPF Pass para o novo envio e preservando o retorno de bounces.	Não alinha com o From original: o pass passa a ser do domínio do encaminhador.
ARC	Cada intermediário registra os resultados de autenticação que observou e sela a cadeia com assinaturas próprias (RFC 8617).	Não transforma SPF ou DMARC em pass. Apenas fornece evidência que o receptor *pode* considerar.
DKIM preservado	Se o intermediário não altera a mensagem, a assinatura original sobrevive e continua alinhada.	Não sobrevive a listas que mudam assunto ou corpo.

11.1 Como ARC funciona

A cada salto que participa, o intermediário acrescenta um **conjunto ARC** com número de instância `i=`:

- `ARC-Authentication-Results` (AAR): cópia dos resultados SPF/DKIM/DMARC que aquele intermediário observou na chegada.
- `ARC-Message-Signature` (AMS): assinatura no estilo DKIM da mensagem naquele momento.
- `ARC-Seal` (AS): sela os conjuntos anteriores e informa `cv=` (`none` no primeiro, `pass` ou `fail` nos seguintes).

```
ARC-Seal: i=1; a=rsa-sha256; cv=none; d=lista.example; s=arc1; b=...
ARC-Message-Signature: i=1; a=rsa-sha256; d=lista.example; s=arc1;
 h=from:to:subject:date; bh=...; b=...
ARC-Authentication-Results: i=1; mx.lista.example;
 spf=pass smtp.mailfrom=empresa.example;
 dkim=pass header.d=empresa.example;
 dmarc=pass header.from=empresa.example
Authentication-Results: mx.destino.example;
 spf=fail smtp.mailfrom=empresa.example;
 dkim=fail header.d=empresa.example;
 dmarc=fail header.from=empresa.example;
 arc=pass (i=1 d=lista.example)
```

Leitura: no destino final o DMARC falhou, mas a cadeia ARC é válida e mostra que, ao chegar à lista, a mensagem passava. Se o receptor **confia no selador** `lista.example`, sua política local pode aceitar a mensagem apesar do DMARC Fail. Essa decisão é local e deve aparecer nos logs.

11.2 Checklist de investigação

01 O SPF falhou com o IP de um encaminhador conhecido? Verifique se ele faz SRS.

02 O DKIM original falhou? Procure mudanças de assunto, rodapé ou recodificação pela lista.

03 Há cabeçalhos ARC? Confira `arc=` no Authentication-Results do seu gateway e o `cv=` do selo mais recente.

04 O selador está na lista de confiança do receptor? Sem confiança, ARC é apenas informativo.

05 Não altere o SPF da origem para autorizar IPs de encaminhadores de terceiros: o problema não é da política do remetente.

STATUS A RFC 8617 é de categoria *Experimental*. Grandes provedores usam ARC, mas o peso dado à cadeia varia por receptor; trate-o como evidência complementar.

12 Domínios que não enviam e-mail NOVO

Domínios estacionados, de marca, de campanha ou de redirecionamento web raramente enviam e-mail, mas são alvos fáceis de spoofing porque costumam não publicar política nenhuma. Sem SPF, o resultado é `none`; sem DMARC, o receptor não tem orientação. A defesa é barata e não tem efeito colateral quando o domínio realmente não envia.

12.1 Kit mínimo de proteção

```
# SPF: nenhum IP está autorizado
estacionado.example.          TXT  "v=spf1 -all"

# DMARC: rejeitar o que alegar este domínio no From
_dmarc.estacionado.example.   TXT  "v=DMARC1; p=reject; sp=reject; np=reject;
                                    rua=mailto:dmarc@empresa.example"

# Null MX (RFC 7505): o domínio também não recebe e-mail
estacionado.example.          MX   0 .

# Opcional: DKIM sem chaves válidas (seletor curinga revogado)
*._domainkey.estacionado.example. TXT "v=DKIM1; p="
```

Registro	Efeito
`v=spf1 -all`	Qualquer IP que use o domínio no MAIL FROM ou HELO recebe SPF Fail. Não gasta consultas DNS.
DMARC `p=reject`	Protege o `From:` visível, que o SPF sozinho não cobre. `sp` cobre subdomínios existentes e `np` (RFC 9989) subdomínios inexistentes.
Null MX `0 .`	Declara que o domínio não aceita e-mail; remetentes falham rápido em vez de enfileirar.
DKIM `p=` vazio	Indica chave revogada para qualquer seletor; prática recomendada por grupos de operadores (M3AAWG), não exigida por RFC.

ANTES DE PUBLICAR Confirme que o domínio realmente não envia: sistemas legados, formulários de site, impressoras multifuncionais e alertas de monitoramento costumam usar domínios "esquecidos". Se houver dúvida, publique DMARC com `p=none` e `rua=` por algumas semanas, analise os relatórios agregados (RFC 9990, capítulo 26) e só então endureça.

12.2 Subdomínios do domínio principal

SPF é avaliado no **nome exato** usado no MAIL FROM ou HELO; não existe herança do domínio pai. Por isso:

- **Subdomínios que existem e não enviam** (`www`, `vpn`, `portal`): publique `v=spf1 -all` em cada um. Um atacante pode usá-los no MAIL FROM e, com `aspf=r`, um SPF permissivo ali alinharia com o domínio principal.
- **Nomes HELO dos seus MTAs**: publique uma política própria, por exemplo `smtp.empresa.example TXT "v=spf1 a -all"`. Isso dá resultado útil para DSNs com MAIL FROM vazio.
- **Subdomínios inexistentes**: o SPF retorna `none` (NXDOMAIN). A proteção do From vem do DMARC do domínio organizacional, via `np=` ou `sp=`.

- **Curingas** (`*.empresa.example TXT "v=spf1 -all"`) só cobrem nomes que não existem no DNS; um nome que já tem qualquer registro (um A, por exemplo) não é coberto. Prefira registros explícitos e use o curinga apenas como complemento consciente.

12.3 Auditoria rápida de um portfólio de domínios

```
# Para cada domínio do inventário: SPF, DMARC e MX
for d in $(cat dominios.txt); do
  echo "== $d"
  dig +short TXT "$d" | grep -i 'v=spf1' || echo "  SPF: ausente"
  dig +short TXT "_dmarc.$d" | grep -i 'v=DMARC1' || echo "  DMARC: ausente"
  dig +short MX "$d" || true
done
```

Classifique cada domínio como **envia**, **só recebe** ou **inativo** antes de aplicar o kit. O inventário e a classificação devem constar do relatório de mudança (capítulo 15).

13 Playbook de investigação em produção

Use o roteiro como checklist operacional. A ordem evita alterações precipitadas no DNS e preserva evidências para auditoria.

01 **ABERTURA:** registre identificador do incidente, impacto, domínios afetados, janela de tempo e exemplos de mensagem.

02 **CAPTURA:** obtenha IP público de origem, EHLO/HELO, MAIL FROM, destinatário, queue-id e horário com fuso.

03 **IDENTIDADE:** determine o nome DNS efetivamente usado no `check_host()` e distinga-o do From visível.

04 **DNS:** colete o TXT completo com TTL e resolvedor; confirme uma única política `v=spf1` para o nome.

05 **AVALIAÇÃO:** interprete os mecanismos em ordem, expanda include/redirect e verifique CIDR, IPv6 e limites.

06 **CONTEXTO:** investigue relays, NAT, SRS, ARC, fornecedor terceiro, mudanças recentes e alterações no DNS.

07 **CORRELAÇÃO:** confronte `spf=` e o `Received-SPF` (mecanismo decisivo) com DKIM, DMARC (inclusive modo de alinhamento), relatórios agregados, decisão SMTP, antispam e reputação.

08 **REMEDIAÇÃO:** proponha a menor mudança necessária, com validação prévia, janela, rollback e responsável.

09 **PÓS-MUDANÇA:** verifique DNS autoritativo, recursivos, cabeçalhos de mensagem de teste e logs de envio.

10 **ENCERRAMENTO:** registre causa raiz, evidências, política antes/depois e medidas para evitar recorrência.

13.1 Comandos de triagem somente leitura (Postfix/Linux)

```
# Parâmetros de configuração personalizados
postconf -n

# Eventos recentes do Postfix (o nome da unidade varia)
journalctl -u postfix --since '1 hour ago' --no-pager

# Logs no syslog, quando presentes
sudo grep -Ei 'spf|reject|policy|NOQUEUE' /var/log/mail.log | tail -n 80

# Fila; requer permissões adequadas
postqueue -p
```

OPERAÇÃO SEGURA Os comandos acima apenas consultam. Evite alterar `main.cf`, policy services, filtros ou DNS de produção antes de identificar a causa raiz. Nomes de serviço e caminhos de log dependem da distribuição e do gateway.

13.2 Proxmox Mail Gateway e outros gateways

Em gateways como o Proxmox Mail Gateway, distinga a classificação do filtro, os logs SMTP do MTA subjacente e o Authentication-Results recebido ou inserido. Resultados e ações podem vir de componentes diferentes; não presuma que toda instalação tenha o mesmo plugin SPF ou a mesma configuração de rejeição.

14 Estudos de caso comentados

Caso A — IP legítimo omitido

```
IP recebido: 192.0.2.50
MAIL FROM:   alertas@empresa.example
TXT:         v=spf1 ip4:192.0.2.10 -all
Resultado:   fail
```

O IP 192.0.2.50 não está autorizado. Se for um emissor legítimo e 192.0.2.10 continuar em uso, a menor correção é `v=spf1 ip4:192.0.2.10 ip4:192.0.2.50 -all`.

Caso B — Include externo com Fail não encerra o principal

```
Principal: v=spf1 include:_spf.parceiro.example ip4:192.0.2.10 -all
Externo:   v=spf1 ip4:198.51.100.10 -all
IP:        192.0.2.10
```

O include externo avalia para fail e não corresponde. A avaliação volta ao principal, chega ao `ip4:192.0.2.10` e retorna pass. O fail externo não é a conclusão final.

Caso C — Dois registros SPF

```
empresa.example. TXT "v=spf1 ip4:192.0.2.10 -all"
empresa.example. TXT "v=spf1 include:_spf.provedor.example -all"
```

Mais de uma política SPF no mesmo nome provoca permerror, ainda que cada registro seja válido isoladamente. Consolide as autorizações em um único TXT.

Caso D — Pass sem alinhamento DMARC

```
IP:        198.51.100.10
MAIL FROM: bounce@fornecedor.example   -> SPF pass
From:      Financeiro <financeiro@empresa.example>
DKIM:      nenhuma assinatura com d= no domínio organizacional empresa.example
```

O SPF Pass pertence a `fornecedor.example`, que tem outro domínio organizacional; não alinha nem em relaxed. Sem DKIM alinhado, o DMARC falha. Soluções: domínio de retorno personalizado (Caso G) ou DKIM com `d=empresa.example`, conforme suporte oficial do fornecedor.

Caso E — Falha intermitente de DNS

Se em determinados horários o registro não puder ser resolvido por timeout ou SERVFAIL, a avaliação pode terminar em temperror, que não equivale a fail por IP não autorizado. Colete respostas de mais de um resolvedor e da autoridade, TTL, horários, erros de transporte e mudanças recentes.

Caso F — IPv6 omitido

O mesmo servidor alterna saída IPv4 192.0.2.10 e IPv6 2001:db8::10. Se a política publicar apenas `ip4:192.0.2.10`, as sessões IPv6 não terão autorização. Acrescente o `ip6` legítimo se essa for a arquitetura prevista.

Caso G — Domínio de retorno personalizado NOVO

```
IP:        198.51.100.10
MAIL FROM: bounce@retorno.empresa.example   -> SPF pass
           (retorno.empresa.example TXT "v=spf1 include:_spf.fornecedor.example -all")
From:      avisos@empresa.example
DMARC:     v=DMARC1; p=reject   (aspf omitido = relaxed)
```

O fornecedor passa a usar um subdomínio da empresa como MAIL FROM. Com `aspf=r`, `retorno.empresa.example` e `empresa.example` têm o mesmo domínio organizacional: SPF alinhado e DMARC Pass, mesmo sem DKIM. Se a política mudar para `aspf=s`, o alinhamento SPF deixa de existir e a entrega passa a depender de DKIM alinhado.

15 Mudanças seguras, validação e rollback

15.1 Antes de editar o DNS

- Inventarie todos os fluxos legítimos: ERP, aplicações, help desk, marketing, CRM, serviços transacionais e gateways.
- Confirme os IPs públicos efetivos e as identidades MAIL FROM/HELO de cada fluxo.
- Prefira autorizações restritas e mecanismos suficientes. Nunca use `+all` como solução emergencial.
- Valide as cadeias de include e as dependências DNS; registre TTL e janela de propagação.
- Confira a compatibilidade com DMARC (modo de alinhamento) e o DKIM alinhado dos emissores terceiros.

15.2 Procedimento recomendado

01 Crie uma cópia textual do registro atual e registre seu TTL e a zona autoritativa.

02 Proponha o novo registro completo e verifique sintaxe, duplicidade e limites de DNS.

03 Teste com IP autorizado, IP não autorizado, IPv4/IPv6 e, quando aplicável, HELO e MAIL FROM vazio.

04 Publique por processo controlado e acompanhe a autoridade DNS e os resolvedores usados.

05 Valide entregas reais com Authentication-Results confiável e logs; compare antes e depois.

06 Faça rollback se surgirem resultados inesperados e preserve o diagnóstico para análise posterior.

15.3 Anti-padrões

Evite	Porque
`+all` para liberar envio	Autoriza qualquer IP; destrói a restrição.
`~all` para "fazer passar"	Softfail não é pass e não autoriza o IP.
Achar que o A de qualquer subdomínio autoriza	`a` sem argumento olha o domínio em avaliação, não todos os hosts.
Publicar vários TXT SPF separados	Gera permerror quando mais de um `v=spf1` é selecionado.
Flattening cego de includes	Fica desatualizado quando o provedor muda seus IPs.
Tratar SPF Pass como prova da identidade visível	Sem alinhamento, não sustenta DMARC.
Deixar domínios inativos sem política	Viram alvo de spoofing; aplique o kit do capítulo 12.

16 Laboratórios de investigação

Resolva primeiro no papel e só então consulte o Apêndice B. Justifique sempre o resultado, a regra aplicada e a recomendação operacional.

Lab 1 — Três IPs e política restritiva

```
SPF: v=spf1 ip4:192.0.2.10 ip4:192.0.2.20 -all
IPs: 192.0.2.10 | 192.0.2.20 | 192.0.2.30
```

Classifique cada IP e proponha a menor mudança para autorizar o terceiro sem ampliar a rede inteira.

Lab 2 — CIDR

```
SPF: v=spf1 ip4:198.51.100.0/25 -all
IPs: 198.51.100.45 | 198.51.100.127 | 198.51.100.128
```

Calcule o intervalo, o número de endereços correspondentes e o resultado de cada IP.

Lab 3 — a, mx e host não autorizado

```
empresa.example       A   192.0.2.10
empresa.example       MX  10 mail.empresa.example
mail.empresa.example  A   192.0.2.20
smtp.empresa.example  A   192.0.2.30
SPF: v=spf1 a mx -all
```

Indique os IPs permitidos e explique por que o terceiro host não passa automaticamente.

Lab 4 — Include antes de ip4

```
Principal: v=spf1 include:_spf.provedor.example ip4:192.0.2.10 -all
Externo:   v=spf1 ip4:198.51.100.10 -all
IPs:       198.51.100.10 | 192.0.2.10 | 203.0.113.40
```

Mostre o caminho do algoritmo para cada IP e destaque o efeito do fail externo.

Lab 5 — Redirect

```
Principal: v=spf1 ip4:192.0.2.10 redirect=_spf.central.example
Central:   v=spf1 ip4:198.51.100.10 -all
IPs:       192.0.2.10 | 198.51.100.10 | 203.0.113.10
```

Indique o resultado de cada IP e explique a diferença entre redirect e include.

Lab 6 — Política inválida

```
TXT 1: "v=spf1 ip4:192.0.2.10 -all"
TXT 2: "v=spf1 include:_spf.vendor.example -all"
```

Defina o resultado esperado e proponha uma correção sem descartar a autorização externa.

Lab 7 — Autenticação e DMARC

```
MAIL FROM: bounce@fornecedor.example
From:      avisos@empresa.example
SPF:       pass (fornecedor.example)
DKIM:      pass (d=empresa.example)
```

O SPF está alinhado ao From? A mensagem pode ter DMARC Pass? Justifique.

Lab 8 — Investigação de produção

```
2026-10-28T13:15-03:00 client_ip=203.0.113.50
helo=relay.interno.example
mailfrom=retornos@empresa.example
SPF=temperror; dns_status=SERVFAIL
smtp_action=451 4.7.1 Temporary failure
```

Identifique o resultado e a resposta SMTP, e explique por que seria inadequado adicionar o IP ao SPF sem investigar o DNS.

Lab 9 — Relaxed ou strict NOVO

```
MAIL FROM: bounce@mkt.empresa.example   -> SPF pass
From:      ofertas@empresa.example
DKIM:      pass (d=plataforma.example)
DMARC A:   v=DMARC1; p=reject
DMARC B:   v=DMARC1; p=reject; aspf=s
```

Determine o resultado DMARC com a política A e com a política B. Que mudança no fornecedor tornaria o fluxo resistente ao modo strict?

Lab 10 — Domínio que não envia NOVO

```
estacionado.example  TXT  "v=spf1 -all"
(sem registro _dmarc)
Mensagem: IP 203.0.113.7 · MAIL FROM ceo@estacionado.example
          From: Diretoria <ceo@estacionado.example>
```

Qual o resultado SPF? A política atual protege o From visível? Liste o que falta para concluir a proteção do domínio.

Lab 11 — Ler um Received-SPF NOVO

```
Received-SPF: PermError
  (mx.destino.example: permanent error in processing domain of empresa.example: Too many DNS lookups)
  client-ip=203.0.113.25;
  envelope-from="nf@empresa.example";
  helo=erp.empresa.example;
  receiver=mx.destino.example;
  identity=mailfrom
```

Qual identidade foi avaliada? O IP 203.0.113.25 está autorizado ou não? Por que outros fluxos do mesmo domínio podem continuar passando? Qual o primeiro passo de correção?

Lab 12 — Linha de relatório agregado NOVO

```
source_ip=198.51.100.150  count=30
policy_evaluated: disposition=none  dkim=fail  spf=fail
reason: type=mailing_list
header_from=empresa.example  envelope_from=empresa.example
auth_results: spf empresa.example=fail
              dkim empresa.example=fail
              dkim lista.example=pass
Política publicada: p=quarantine
```

Por que a disposição foi `none` se o DMARC falhou e a política é quarentena? O que aconteceu com as mensagens? Deve-se autorizar 198.51.100.150 no SPF da empresa?

17 Incidente completo: do alerta à causa raiz

> **CENÁRIO DIDÁTICO** Todos os domínios, endereços, horários, cabeçalhos e logs desta parte são fictícios. O laboratório dos capítulos 20 e 21 reproduz os resultados SPF sem consultar DNS externo.

17.1 O problema observado

Após migrar a saída do ERP para um novo relay, o destinatário passou a sinalizar SPF Fail. O serviço de marketing continuou entregando. A hipótese inicial é uma autorização ausente, mas ela precisa ser demonstrada pelo IP recebido e pela política efetivamente avaliada.

```
Data:                2026-10-28 13:15:00 -03:00
IP recebido:         192.0.2.50
EHLO:                smtp.empresa.example
MAIL FROM:           alertas@empresa.example
From:                ERP <alertas@empresa.example>
Queue-ID no receptor: LAB42
SPF observado:       fail
Ação local:          aceitar e registrar
```

17.2 Política capturada no momento do teste

```
empresa.example        TXT "v=spf1 include:_spf.parceiro.example -all"
_spf.parceiro.example  TXT "v=spf1 ip4:198.51.100.10 -all"
```

O receptor viu 192.0.2.50. Não substitua esse IP pelo endereço privado do ERP nem pelo IP obtido ao resolver o nome do From. O registro do parceiro autoriza 198.51.100.10, que não corresponde à conexão do ERP.

17.3 Trilha que explica o resultado

Etapa	Evidência e conclusão
1	O include consome um termo de consulta e avalia o mesmo IP no domínio do parceiro.
2	O ip4 externo não corresponde; o -all externo retorna fail.
3	O include não corresponde; a avaliação principal continua.
4	O -all principal corresponde e encerra com fail.

Causa raiz proposta: o novo IP legítimo de saída não consta da política. Antes de corrigir, confirme sua titularidade e o fluxo de NAT/relay nos logs internos; o resultado SPF sozinho não prova legitimidade.

18 Coleta DNS que pode ser auditada

Em um incidente real, substitua os nomes .example e os IPs de documentação. Execute a coleta também a partir do ambiente do receptor, quando possível; resolvedores públicos servem de comparação, não de prova do que o gateway recebeu.

```
date -Is
dig TXT empresa.example +noall +answer +comments +stats
dig NS empresa.example +short

# Use o IP real de um NS autoritativo identificado:
dig @192.0.2.53 empresa.example TXT +norecurse

# Use o resolvedor realmente consultado pelo gateway:
dig @192.0.2.54 empresa.example TXT
dig @192.0.2.54 _spf.parceiro.example TXT
```

Confira status, presença da flag `aa` na resposta autoritativa, TTL, SERVER e WHEN. Consultar com `+norecurse` não torna o servidor autoritativo: confirme a autoridade da zona e a delegação. Com vários NS, compare todos.

18.1 Resposta ilustrativa e leitura

```
;; ->>HEADER<<- opcode: QUERY, status: NOERROR
;; flags: qr aa; QUERY: 1, ANSWER: 1
empresa.example. 300 IN TXT "v=spf1 include:_spf.parceiro.example -all"
;; Query time: 8 msec
;; SERVER: 192.0.2.53#53
;; WHEN: Wed Oct 28 13:15:00 -03 2026
```

NOERROR não significa SPF Pass. `ANSWER: 1` indica uma resposta DNS, não uma autorização. O TTL 300 é expresso em segundos.

18.2 Diagnóstico por resposta

Resposta	Como registrar e investigar
NOERROR / zero respostas	NODATA para o tipo consultado; guarde também a seção de autoridade.
NXDOMAIN	O nome não existe. Distinga a consulta inicial de uma consulta feita dentro de include.
SERVFAIL / timeout	Falha de resolução; avalie autoridade, rede, resolvedor e eventual validação DNSSEC.
Respostas divergentes	Compare TTLs, caches, publicação nos NS e horários de coleta.

Uma consulta feita depois do incidente descreve o DNS naquele novo instante. Preserve respostas contemporâneas, versões da zona e histórico de mudanças. Sem esse histórico, declare a limitação em vez de afirmar que reproduziu a política antiga.

19 Cabeçalhos, confiança e conclusão

O exemplo representa uma mensagem aceita pelo receptor para análise. Em uma rejeição durante a sessão SMTP, pode não existir mensagem entregue nem Authentication-Results: os logs SMTP passam a ser a evidência principal.

```
Return-Path: <alertas@empresa.example>
Received: from smtp.empresa.example (unknown [192.0.2.50])
 by mx.destino.example with ESMTP id LAB42;
 Wed, 28 Oct 2026 13:15:00 -0300
Authentication-Results: mx.destino.example;
 spf=fail smtp.mailfrom=empresa.example;
 dkim=none;
 dmarc=fail header.from=empresa.example
From: ERP <alertas@empresa.example>
To: Operacao <alvo@destino.example>
Date: Wed, 28 Oct 2026 13:14:58 -0300
Message-ID: <lab42@empresa.example>
Subject: Alerta de teste

Mensagem ficticia para investigacao.
```

Neste cenário, presume-se uma política DMARC aplicável e ausência de DKIM alinhado. O domínio do MAIL FROM é igual ao do From, mas o SPF falhou; não há método alinhado com pass que sustente DMARC Pass.

19.1 O que torna a evidência confiável

Confirme com a equipe do receptor que `mx.destino.example` é o identificador de autenticação autorizado e que o cabeçalho foi inserido por ele; a simples presença do nome no texto não basta. Correlacione LAB42 com o log local e identifique o salto recebido pela infraestrutura confiável. Linhas anteriores podem ter sido fornecidas por terceiros [RFC 8601].

19.2 Correção mínima e testes

```
v=spf1 ip4:192.0.2.50 include:_spf.parceiro.example -all
```

A proposta mantém a autorização do parceiro e acrescenta somente o novo IPv4 confirmado. No laboratório, o ERP passa, o parceiro continua passando e um IP estranho continua falhando. IPv6 permanece sem autorização neste cenário; se houver fluxo legítimo, inventarie e autorize o endereço separadamente.

19.3 Encerramento do incidente

Registre política antes/depois, responsável, evidência de legitimidade do IP, resultados dos testes e horário da mudança. Após publicar, confira a autoridade, o resolvedor do receptor e uma mensagem de teste real. A aceitação em um destinatário não demonstra aceitação universal.

20 Laboratório: preparação e resultados

O pySPF é um avaliador de SPF. Aqui substituímos apenas sua função de acesso ao DNS por uma zona em memória; o algoritmo continua sendo executado pela biblioteca. O laboratório não testa transporte DNS, TTL, DNSSEC, DKIM, DMARC nem políticas de entrega.

20.1 Preparar um ambiente isolado

```
python3 -m venv .venv-spf
. .venv-spf/bin/activate
python -m pip install pyspf==2.0.14 dnspython
python -m pip freeze > requisitos-spf.txt
python --version >> requisitos-spf.txt

# Salve o código do capítulo 21 como lab_spf.py (ou extraia o anexo do PDF)
python lab_spf.py
```

A instalação exige acesso ao repositório de pacotes; depois disso, o script roda sem DNS externo. A versão do pySPF foi fixada para estabilidade; registre também a versão do Python.

> **AVISO ESPERADO** No Python 3.12 ou superior, o pySPF 2.0.14 emite um `SyntaxWarning: invalid escape sequence` vindo de uma docstring da própria biblioteca. É inofensivo e não afeta os resultados; para ocultá-lo, use `python -W ignore lab_spf.py`.

20.2 Saída verificada nesta revisão

```
ANTES
192.0.2.50 fail
198.51.100.10 pass
DEPOIS
192.0.2.50 pass
198.51.100.10 pass
203.0.113.99 fail
2001:db8::50 fail
SEM ENVIO
203.0.113.7 fail
SUBDOMINIO
198.51.100.200 pass
198.51.100.200 fail
CABECALHO
Received-SPF: Fail
  (mx.destino.example: domain of empresa.example does not designate 203.0.113.99 as permitted sender)
  client-ip=203.0.113.99;
  envelope-from="alertas@empresa.example";
  helo=smtp.empresa.example;
  receiver=mx.destino.example;
  mechanism=-all;
  identity=mailfrom
LIMITE
192.0.2.50 permerror
```

As dez verificações usam `assert`: qualquer resultado diferente interrompe a execução com erro. "SEM ENVIO" confirma o comportamento de `v=spf1 -all` (capítulo 12); "SUBDOMINIO" mostra o orçamento separado de um subdomínio de envio (capítulo 25); "CABECALHO" imprime o `Received-SPF` gerado pelo avaliador (seção 8.3). O último teste monta uma cadeia de onze includes e comprova a proteção de limite.

20.3 Experimentos sugeridos

- Troque o `-all` principal por `~all` e ajuste o resultado esperado do IP estranho para `softfail`.
- Remova a política do parceiro da zona: o include alcançado passa a produzir `permerror`.
- Reduza a cadeia para dez includes no total e confirme que o resultado volta a ser `fail`.

Faça uma mudança por vez e anote hipótese, saída e interpretação.

21 Código completo do laboratório

Testado com pySPF 2.0.14 em Python 3.13. Também anexado internamente a este PDF como `lab_spf.py`.

```
import spf

zone = {
    'empresa.example':
        'v=spf1 include:_spf.parceiro.example -all',
    '_spf.parceiro.example':
        'v=spf1 ip4:198.51.100.10 -all',
    'estacionado.example':
        'v=spf1 -all',
}

def dns_local(name, qtype, *args, **kwargs):
    key = str(name).lower().rstrip('.')
    if qtype == 'TXT' and key in zone:
        return [((name, qtype), [zone[key].encode()])]
    return []

# Somente neste processo: nenhum DNS externo e consultado.
spf.DNSLookup = dns_local

def testar(ip, esperado, remetente='alertas@empresa.example'):
    resultado, _ = spf.check2(
        i=ip, s=remetente,
        h='smtp.empresa.example')
    print(ip, resultado)
    assert resultado == esperado, (resultado, esperado)

print('ANTES')
testar('192.0.2.50', 'fail')
testar('198.51.100.10', 'pass')

zone['empresa.example'] = (
    'v=spf1 ip4:192.0.2.50 '
    'include:_spf.parceiro.example -all')

print('DEPOIS')
testar('192.0.2.50', 'pass')
testar('198.51.100.10', 'pass')
testar('203.0.113.99', 'fail')
testar('2001:db8::50', 'fail')

# Dominio que nao envia e-mail: qualquer IP falha.
print('SEM ENVIO')
testar('203.0.113.7', 'fail', 'ceo@estacionado.example')

# Subdominio de envio: SPF e orcamento de consultas proprios.
zone['mkt.empresa.example'] = 'v=spf1 include:_spf.plataforma.example -all'
zone['_spf.plataforma.example'] = 'v=spf1 ip4:198.51.100.200 -all'
print('SUBDOMINIO')
testar('198.51.100.200', 'pass', 'news@mkt.empresa.example')
testar('198.51.100.200', 'fail')  # o dominio principal nao autoriza a plataforma

# Cabecalho Received-SPF gerado pelo proprio avaliador (RFC 7208, 9.1).
print('CABECALHO')
q = spf.query(i='203.0.113.99', s='alertas@empresa.example',
              h='smtp.empresa.example', receiver='mx.destino.example')
res, _, _ = q.check()
cab = q.get_header(res, receiver='mx.destino.example')
resultado, resto = cab.split(' ', 1)
comentario, campos = resto.split(') ', 1)
```

```
print('Received-SPF: ' + resultado)
print('  ' + comentario + ')')
print('  ' + campos.replace('; ', ';\n  '))

# Cadeia de 11 includes: excede o limite global de 10.
zone['empresa.example'] = 'v=spf1 include:n1.example -all'
for n in range(1, 11):
    zone[f'n{n}.example'] = f'v=spf1 include:n{n+1}.example -all'
zone['n11.example'] = 'v=spf1 -all'

print('LIMITE')
testar('192.0.2.50', 'permerror')
```

22 Contagem de consultas sem atalhos

Considere o IP 203.0.113.9 e as políticas abaixo. Todos os nomes retornam TXT válidos; não há consultas vazias. Nenhum dos ip4 corresponde ao IP testado.

```
empresa.example: v=spf1 include:a.example include:b.example -all
a.example:       v=spf1 include:c.example -all
c.example:       v=spf1 ip4:192.0.2.1 -all
b.example:       v=spf1 include:d.example -all
d.example:       v=spf1 ip4:198.51.100.1 -all
```

Ordem	Termo alcançado	Acumulado
1	`include:a.example`, no principal	1
2	`include:c.example`, dentro de a	2
3	`include:b.example`, após o retorno de a	3
4	`include:d.example`, dentro de b	4
Final	`-all` do principal: fail	4

Os fails externos tornam os respectivos includes não correspondentes. `ip4` e `all` não somam. A busca inicial pelo TXT principal não é um termo desse orçamento. Se o IP fosse 192.0.2.1, a avaliação encerraria com pass no primeiro ramo, com total de dois.

22.1 Um caso que ultrapassa dez

No script, o principal chama n1 (1º include), n1 chama n2 (2º), e assim por diante; n9 chama n10 (10º). Ao alcançar o include de n10 para n11, seria necessário o 11º termo: o resultado é permerror, sem precisar chegar ao `-all` final.

22.2 Três controles diferentes

Mantenha separados: orçamento global de termos, consultas vazias e expansão de MX/PTR. Um registro pode respeitar os dez termos e violar outro limite. Cache DNS não transforma um termo avaliado em custo zero [RFC 7208, 4.6.4].

No `mx`, a expansão de cada mecanismo não pode consultar mais de dez registros de endereço (A/AAAA); excedê-lo produz permerror. Em `ptr` e na macro `%{p}`, os nomes além dos dez primeiros são ignorados. Esses limites não são recomendação para publicar políticas no limite máximo.

22.3 Exercício adicional

Mova `ip4:203.0.113.9` para antes do primeiro include no registro principal. Qual o novo resultado e o orçamento? **Resposta:** pass e zero termos de consulta avaliados, sem deixar de existir a busca inicial do TXT e a validação da sintaxe.

23 Macros, exists e armadilhas de sintaxe

23.1 Por que aparecem nomes diferentes no DNS

Macros constroem o nome consultado a partir dos dados da avaliação: `%{i}` representa o IP; `%{d}`, o domínio atualmente avaliado; `%{s}`, o remetente. Em include/redirect, o domínio da avaliação muda, mas IP e remetente são preservados [RFC 7208, 7].

```
v=spf1 exists:%{i}._autorizados.empresa.example -all
# Para IPv4 192.0.2.50, o nome expandido é:
192.0.2.50._autorizados.empresa.example
```

`exists` consulta A e corresponde se houver ao menos um endereço na resposta; não compara esse endereço com o IP SMTP. Uma resposta `A 127.0.0.2` já satisfaz o mecanismo; uma resposta apenas AAAA não satisfaz, mesmo em conexão IPv6 [RFC 7208, 5.7].

23.2 Investigação prática

```
dig A 192.0.2.50._autorizados.empresa.example
# Registre o nome depois da expansão, não apenas o modelo.
```

Não aplique a expansão IPv4 mecanicamente ao IPv6 (que usa nibbles em notação de pontos); consulte a sintaxe de macros da RFC e o rastreio do avaliador. Evite dados pessoais reais em exemplos públicos de macros de remetente.

23.3 Sintaxe é verificada antes da correspondência

```
v=spf1 ip4:192.0.2.50 mecanismo_inexistente -all
```

Mesmo que o IP corresponda ao primeiro ip4, o registro é inválido. A sintaxe da política inteira deve ser validada; "o primeiro mecanismo correspondeu" não justifica ignorar uma falha estrutural posterior [RFC 7208, 4.6].

23.4 Uma resposta TXT pode ter várias strings

```
"v=spf1 ip4:192.0.2.50 " "include:_spf.parceiro.example -all"
```

As strings de um mesmo TXT são concatenadas sem espaço automático; o espaço ao fim da primeira string é necessário neste exemplo. Duas strings em um registro não equivalem a dois registros SPF [RFC 7208, 3.3].

24 Avaliação com DNS real e mudanças seguras

Use esta variante somente após substituir os três valores pelos dados de uma sessão real. O código consulta o DNS do ambiente onde é executado; não envia e-mail nem altera registros. Execute em um novo processo, sem a substituição de DNS do laboratório.

```
python - <<'PYCODE'
import spf
resultado, explicacao = spf.check2(
    i='192.0.2.50',
    s='alertas@empresa.example',
    h='smtp.empresa.example')
print('SPF:', resultado)
print('Explicacao:', explicacao)
PYCODE
```

Os nomes .example não têm as políticas do laboratório no DNS público; executar o modelo literalmente não reproduz os resultados da zona em memória. `check2` retorna resultado e explicação; não determina a resposta SMTP do seu gateway.

24.1 Matriz mínima antes de publicar

Teste	Resultado esperado na proposta
ERP / 192.0.2.50	pass
Parceiro / 198.51.100.10	pass
IP estranho / 203.0.113.99	fail
IPv6 não inventariado	fail; investigar se existe fluxo legítimo
MAIL FROM vazio	Avaliar o domínio HELO correspondente, em teste próprio
Destinatário de teste	Conferir autenticação, alinhamento DMARC e decisão real nos logs

24.2 Publicação e rollback

Guarde o TXT completo anterior, TTL, autoridade, versão da zona e responsável. Se for reduzir o TTL para uma mudança planejada, faça isso com antecedência: caches que já guardaram o valor antigo seguem o TTL anterior. Após a alteração, verifique todos os NS autoritativos e o resolvedor do receptor. O rollback também depende dos caches; republicar o valor antigo não apaga imediatamente as respostas armazenadas.

24.3 Critério de conclusão

Conclua quando o fluxo legítimo passar no teste real, os emissores existentes permanecerem autorizados, o IP estranho continuar sem autorização e os logs confirmarem a identidade esperada. Uma captura de ferramenta web não é aceite técnico.

25 Estratégias para não estourar o limite de 10 NOVO

O capítulo 7 explica como diagnosticar o permerror por excesso de consultas. Este capítulo trata da prevenção: como manter a política dentro do orçamento à medida que a empresa contrata novos serviços de envio, sem abrir mão da restrição.

25.1 Meça o pior caso, não o caso comum

O orçamento só é consumido até a primeira correspondência. Por isso, um IP legítimo que casa logo no início passa, enquanto um IP que não casa com nada percorre **todos** os ramos. O pior caso é sempre o IP não autorizado.

> **SINTOMA CLÁSSICO** "O SPF dá permerror só para alguns IPs" ou "só para o fornecedor que está no fim do registro". Antes de procurar problema de DNS, conte os termos do caminho completo: a política provavelmente estourou o limite e só os fluxos que casam cedo escapam.

Para medir, percorra a política com um IP de documentação que não esteja autorizado (por exemplo, 203.0.113.99), expanda cada include e redirect e some os termos como no capítulo 22. Inclua os includes aninhados dos provedores: eles mudam sem aviso, então repita a medição periodicamente e registre a data.

25.2 Técnicas, do menor ao maior risco

Técnica	Efeito	Cuidados
Remover termos mortos	Includes de fornecedores desativados, `a` / `mx` que não enviam e `ptr` saem da política.	Confirme no inventário e nos relatórios DMARC (capítulo 26) que o fluxo realmente acabou.
Trocar `a` / `mx` por `ip4` / `ip6`	Cada troca economiza um termo; IP literal não consome consulta.	Só para IPs próprios e estáveis. Uma mudança de IP do servidor passa a exigir mudança no SPF.
Subdomínio de envio por fluxo	Cada fluxo (marketing, CRM, notas fiscais) usa um MAIL FROM próprio, com SPF e **orçamento próprios**. Também isola reputação e falhas.	Exige que o fornecedor aceite domínio de retorno personalizado. Alinha com o From em modo relaxed (capítulo 9); em `aspf=s`, dependa de DKIM alinhado.
Flattening automatizado	Ferramenta que resolve periodicamente os includes do fornecedor e publica os IPs como `ip4` / `ip6`.	Precisa de monitoramento contínuo: se a automação parar, os IPs ficam desatualizados e o envio falha. Nunca faça flattening manual "uma vez só".
Macros com `exists`	Orçamento constante: uma consulta por avaliação, independentemente do número de IPs (capítulo 23).	Exige zona DNS dinâmica própria e mais complexidade de operação. Raramente compensa fora de grandes provedores.

25.3 Exemplo de reorganização

Política inicial de `empresa.example`, com a contagem de pior caso de cada termo (incluindo os aninhados de cada fornecedor):

```
v=spf1 a mx include:_spf.erp.example include:_spf.mkt.example
       include:_spf.crm.example include:_spf.helpdesk.example -all

# a=1  mx=1  erp=1  mkt=1+3  crm=1+2  helpdesk=1  -> total 12: permerror no pior caso
```

Reorganização: o ERP continua no domínio principal; marketing e CRM passam a usar subdomínios de retorno; os servidores próprios viram IPs literais.

Nome (MAIL FROM)	Política	Pior caso
`empresa.example`	`v=spf1 ip4:192.0.2.50 include:_spf.erp.example include:_spf.helpdesk.example -all`	2
`mkt.empresa.example`	`v=spf1 include:_spf.mkt.example -all`	4
`crm.empresa.example`	`v=spf1 include:_spf.crm.example -all`	3

Cada nome é avaliado separadamente, com seu próprio orçamento de 10. O laboratório do capítulo 21 tem um teste (SUBDOMINIO) que mostra o mesmo IP passando no subdomínio e falhando no domínio principal: a separação também limita o que cada fornecedor pode autorizar.

25.4 Domínio de retorno com CNAME

Muitos fornecedores pedem que o subdomínio de retorno seja um CNAME para a infraestrutura deles:

```
retorno.empresa.example.  CNAME  bounces.plataforma.example.
# A avaliação SPF de retorno.empresa.example segue o CNAME e usa o TXT do fornecedor.
```

- O fornecedor mantém os IPs atualizados sem que você mexa no DNS, e o nome continua sendo seu (alinha em relaxed).
- Um nome com CNAME não pode ter outros registros; use um subdomínio dedicado, nunca o domínio principal.
- Ao encerrar o contrato, **remova o CNAME**. Um CNAME apontando para um recurso que o fornecedor liberou pode ser assumido por terceiros e autorizar envio em nome da empresa.

25.5 Tamanho do registro

Cada string de um TXT tem no máximo 255 caracteres; registros maiores usam várias strings no mesmo TXT (capítulo 23.4). A RFC 7208 (seção 3.4) recomenda manter a resposta DNS pequena o bastante para caber em 512 octetos via UDP; respostas maiores dependem de EDNS ou TCP e falham mais em redes restritivas, o que aparece como temperror intermitente. Flattening tende a inflar o registro: confira o tamanho junto com a contagem de termos.

> **PROCEDIMENTO** Toda reorganização é uma mudança de DNS em produção: siga o capítulo 15 (inventário, proposta completa, testes, publicação, rollback) e use a matriz do capítulo 24.1 incluindo um IP de cada fornecedor.

26 Relatórios DMARC agregados na investigação NOVO

Quando um domínio publica `rua=mailto:...` na política DMARC, os receptores enviam periodicamente (em geral uma vez por dia) relatórios agregados em XML com todos os IPs que usaram o domínio no From, quantas mensagens cada um enviou e como SPF, DKIM e DMARC foram avaliados. É a única fonte que mostra fluxos que você **não** conhece: fornecedores esquecidos, encaminhamentos e tentativas de spoofing.

26.1 Formato e entrega

- O formato atual é definido pela **RFC 9990**: elemento raiz `feedback` com namespace `urn:ietf:params:xml:ns:dmarc-2.0`. Muitos receptores ainda enviam o formato legado da RFC 7489, sem namespace; o script deste capítulo aceita os dois.
- Nome do arquivo: `receptor!dominio!inicio!fim[!id].xml.gz`, com datas em segundos desde 1970. A RFC recomenda gzip, mas arquivos `.zip` continuam comuns.
- Se o endereço de `rua` estiver em outro domínio, esse domínio precisa autorizar o recebimento publicando `empresa.example._report._dmarc.terceiro.example`; sem isso, receptores não enviam.

26.2 Anatomia de um registro

```
<record>
  <row>
    <source_ip>198.51.100.77</source_ip>        <- IP da conexão SMTP
    <count>85</count>                           <- mensagens no período
    <policy_evaluated>                          <- resultado DMARC (ALINHADO)
      <disposition>quarantine</disposition>
      <dkim>fail</dkim>
      <spf>fail</spf>
    </policy_evaluated>
  </row>
  <identifiers>
    <header_from>empresa.example</header_from>
    <envelope_from>bounce.fornecedor.example</envelope_from>
  </identifiers>
  <auth_results>                                <- resultados BRUTOS
    <spf>
      <domain>bounce.fornecedor.example</domain>
      <scope>mfrom</scope>
      <result>pass</result>
    </spf>
  </auth_results>
</record>
```

A DISTINÇÃO MAIS IMPORTANTE `policy_evaluated/spf` e `policy_evaluated/dkim` dizem se o método passou **e estava alinhado** com o From. `auth_results` traz o resultado bruto de cada verificação, para o domínio que ela autenticou. No exemplo, o SPF bruto passou para `bounce.fornecedor.example`, mas não alinhou com `empresa.example`: para o DMARC, conta como fail.

26.3 Combinações e diagnóstico

Padrão no relatório	Diagnóstico provável e próximo passo
Bruto pass, alinhado fail (SPF ou DKIM)	Fornecedor autenticando com o próprio domínio. Configure domínio de retorno ou DKIM com o domínio da empresa (capítulos 9 e 25).
SPF bruto fail, DKIM alinhado pass	Encaminhamento ou relay intermediário; o DKIM sustentou o DMARC. Normalmente não exige ação no SPF (capítulo 11).
SPF e DKIM fail, IP desconhecido, volume baixo	Spoofing ou fluxo não inventariado. Verifique DNS reverso, rede de origem e se alguém da empresa reconhece o IP antes de concluir.
SPF e DKIM fail, IP de serviço contratado	Fluxo legítimo sem autenticação. Corrija antes de endurecer a política, ou ele será rejeitado.
`disposition` diferente da política	Veja `reason/type`: `local_policy`, `mailing_list`, `trusted_forwarder`, `policy_test_mode`. O receptor aplicou exceção local (por exemplo, com base em ARC).

26.4 Resumo automatizado

O script `dmarc_resumo.py` (anexado a este PDF e reproduzido no fim do capítulo) lê arquivos `.xml`, `.xml.gz` e `.zip`, agrupa os registros e lista primeiro as fontes que falham DMARC. Não acessa a rede.

```
python -m pip install defusedxml
python -I dmarc_resumo.py relatorios/
```

Saída verificada com dois relatórios fictícios desta revisão, um no formato RFC 9990 (gzip) e outro no formato legado (zip):

```
RELATORIOS
  destino.example        dominio=empresa.example p=quarantine aspf=r adkim=r
  outro.example          dominio=empresa.example p=quarantine aspf=r adkim=r

MENSAGENS: 1731   DMARC FAIL: 97

FALHAM DMARC (investigar primeiro)
198.51.100.77    qtd=85     alinhado spf/dkim=fail/fail  acao=quarantine
   from=empresa.example  envelope=bounce.fornecedor.example
   spf bruto=bounce.fornecedor.example:pass  dkim bruto=-
203.0.113.66     qtd=12     alinhado spf/dkim=fail/fail  acao=quarantine
   from=empresa.example  envelope=empresa.example
   spf bruto=empresa.example:fail  dkim bruto=-

TODAS AS FONTES
198.51.100.200   qtd=1200   alinhado spf/dkim=pass/fail  acao=pass
   from=empresa.example  envelope=mkt.empresa.example
   spf bruto=mkt.empresa.example:pass  dkim bruto=plataforma.example:pass
192.0.2.50       qtd=340    alinhado spf/dkim=pass/pass  acao=pass
   from=empresa.example  envelope=empresa.example
   spf bruto=empresa.example:pass  dkim bruto=empresa.example:pass
192.0.2.50       qtd=90     alinhado spf/dkim=pass/pass  acao=none
   from=empresa.example  envelope=empresa.example
   spf bruto=empresa.example:pass  dkim bruto=empresa.example:pass
198.51.100.77    qtd=85     alinhado spf/dkim=fail/fail  acao=quarantine
   from=empresa.example  envelope=bounce.fornecedor.example
   spf bruto=bounce.fornecedor.example:pass  dkim bruto=-
203.0.113.66     qtd=12     alinhado spf/dkim=fail/fail  acao=quarantine
   from=empresa.example  envelope=empresa.example
   spf bruto=empresa.example:fail  dkim bruto=-
```

```
203.0.113.140    qtd=4      alinhado spf/dkim=fail/pass  acao=none
   from=empresa.example  envelope=empresa.example
   spf bruto=empresa.example:fail  dkim bruto=empresa.example:pass
```

26.5 Leitura da saída

Fonte	Interpretação
198.51.100.77	85 mensagens de um fornecedor que autentica SPF com o próprio domínio de bounce e não assina DKIM com o domínio da empresa. Está sendo quarentenado. É fluxo legítimo a corrigir, não ataque: identificar o serviço e configurar domínio de retorno ou DKIM.
203.0.113.66	12 mensagens com SPF fail e sem DKIM. Provável spoofing; a política já está atuando. Acompanhar volume e origem.
203.0.113.140	SPF fail, DKIM alinhado pass: encaminhamento. Nenhuma ação no SPF.
198.51.100.200	Marketing alinhado **apenas por SPF relaxed** (subdomínio `mkt`); o DKIM usa o domínio da plataforma. Se a empresa adotar `aspf=s`, estas 1.200 mensagens passam a falhar (ver Lab 9).
192.0.2.50	ERP com SPF e DKIM alinhados nos dois receptores. Situação desejada.

26.6 Cuidados

- **XML de terceiros:** relatórios chegam de qualquer remetente. Processe com `defusedxml` e limite de tamanho, como faz o script.
- **Relatórios são autodeclarados:** qualquer um pode enviar um XML ao seu endereço `rua`. Use-os para descobrir e priorizar, e confirme com logs e cabeçalhos antes de concluir.
- **Privacidade:** relatórios agregados trazem IPs e volumes; relatórios de falha (`ruf`, RFC 9991) podem conter dados pessoais e exigem tratamento conforme a política interna.
- **Período:** analise ao menos duas a quatro semanas antes de endurecer a política, para capturar fluxos mensais (folha, faturamento, boletos).

26 Código do resumo de relatórios DMARC (continuação)

Testado em Python 3.13 com defusedxml 0.7.1. Também anexado internamente a este PDF como `dmarc_resumo.py`.

```
#!/usr/bin/env python3
"""Resumo de relatorios DMARC agregados (RFC 9990 e formato legado RFC 7489).

Uso:  python dmarc_resumo.py relatorio1.xml.gz relatorio2.zip pasta_de_relatorios/
Aceita .xml, .xml.gz, .gz e .zip. Somente leitura: nao envia nada pela rede.
"""
import gzip, io, sys, zipfile
from collections import defaultdict
from pathlib import Path

try:
    from defusedxml.ElementTree import fromstring  # recomendado: XML vem de terceiros
except ImportError:
    from xml.etree.ElementTree import fromstring
    print('AVISO: instale defusedxml para processar XML nao confiavel.', file=sys.stderr)

LIMITE = 50 * 1024 * 1024  # recusa arquivos descompactados acima de 50 MB


def ler_xmls(caminho):
    """Devolve o conteudo XML de um arquivo, descompactando se preciso."""
    dados = caminho.read_bytes()
    if dados[:2] == b'\x1f\x8b':                        # gzip
        with gzip.open(io.BytesIO(dados)) as g:
            yield g.read(LIMITE + 1)
    elif dados[:2] == b'PK':                            # zip
        with zipfile.ZipFile(io.BytesIO(dados)) as z:
            for info in z.infolist():
                if info.filename.lower().endswith('.xml') and info.file_size <= LIMITE:
                    yield z.read(info)
    else:
        yield dados


def sem_ns(elem):
    """Remove o namespace (dmarc-2.0) para tratar os dois formatos igual."""
    for e in elem.iter():
        if isinstance(e.tag, str) and '}' in e.tag:
            e.tag = e.tag.split('}', 1)[1]
    return elem


def txt(elem, caminho, padrao='-'):
    achado = elem.find(caminho)
    return achado.text.strip() if achado is not None and achado.text else padrao


def processar(xml, linhas, meta):
    raiz = sem_ns(fromstring(xml))
    meta.append((txt(raiz, 'report_metadata/org_name'),
                 txt(raiz, 'policy_published/domain'),
                 txt(raiz, 'policy_published/p'),
                 txt(raiz, 'policy_published/aspf', 'r'),
                 txt(raiz, 'policy_published/adkim', 'r')))
    for rec in raiz.findall('record'):
        dkim_bruto = ','.join(f"{txt(d, 'domain')}:{txt(d, 'result')}"
                              for d in rec.findall('auth_results/dkim')) or '-'
        spf_bruto = (f"{txt(rec, 'auth_results/spf/domain')}:"
                     f"{txt(rec, 'auth_results/spf/result')}")
        chave = (txt(rec, 'row/source_ip'),
```

```
                txt(rec, 'identifiers/header_from'),
                txt(rec, 'identifiers/envelope_from'),
                spf_bruto, dkim_bruto,
                txt(rec, 'row/policy_evaluated/spf'),
                txt(rec, 'row/policy_evaluated/dkim'),
                txt(rec, 'row/policy_evaluated/disposition'))
        linhas[chave] += int(txt(rec, 'row/count', '0'))


def main(argv):
    arquivos = []
    for a in argv:
        p = Path(a)
        arquivos += sorted(x for x in p.iterdir() if x.is_file()) if p.is_dir() else [p]
    linhas, meta = defaultdict(int), []
    for arq in arquivos:
        for xml in ler_xmls(arq):
            if len(xml) > LIMITE:
                print(f'IGNORADO (grande demais): {arq}', file=sys.stderr)
                continue
            processar(xml, linhas, meta)

    print('RELATORIOS')
    for org, dom, p, aspf, adkim in meta:
        print(f'  {org:<22} dominio={dom} p={p} aspf={aspf} adkim={adkim}')

    total = sum(linhas.values())
    falhas = {k: v for k, v in linhas.items() if k[5] != 'pass' and k[6] != 'pass'}
    print(f'\nMENSAGENS: {total}   DMARC FAIL: {sum(falhas.values())}')

    for titulo, conjunto in (('\nFALHAM DMARC (investigar primeiro)', falhas),
                             ('\nTODAS AS FONTES', linhas)):
        print(titulo)
        for k, v in sorted(conjunto.items(), key=lambda kv: -kv[1]):
            ip, hf, ef, sb, db, sa, da, disp = k
            print(f'{ip:<16} qtd={v:<6} alinhado spf/dkim={sa}/{da}  acao={disp}')
            print(f'   from={hf}  envelope={ef}')
            print(f'   spf bruto={sb}  dkim bruto={db}')


if __name__ == '__main__':
    if len(sys.argv) < 2:
        sys.exit(__doc__)
    main(sys.argv[1:])
```

A Modelo de relatório de incidente

Preencha um relatório por fluxo ou mensagem analisada. Armazene cabeçalhos e logs segundo a política interna de retenção e privacidade; anonimize dados pessoais antes de compartilhar.

Campo	Preenchimento
ID do incidente	
Analista / data / fuso	
Domínio do MAIL FROM	
HELO/EHLO	
From visível	
IP efetivo de origem	
Queue-ID / Message-ID	
Política SPF atual (TXT e TTL)	
Includes e redirects avaliados	
Resultado SPF e mecanismo decisivo (Received-SPF)	
Política DMARC (p, aspf, adkim)	
Resultado DKIM / DMARC / ARC	
Fonte nos relatórios agregados (IP, volume, período)	
Ação SMTP efetiva	
Causa raiz	
Correção proposta	
Plano de rollback	
Evidência após a mudança	
Responsável pelo encerramento	

B Gabarito comentado

Lab 1

192.0.2.10 = pass; 192.0.2.20 = pass; 192.0.2.30 = fail. Correção mínima: `v=spf1 ip4:192.0.2.10 ip4:192.0.2.20 ip4:192.0.2.30 -all`.

Lab 2

198.51.100.0/25 tem 128 endereços, de .0 a .127. Os IPs .45 e .127 correspondem (pass); .128 fica fora (fail).

Lab 3

`a` corresponde a 192.0.2.10; `mx` consulta `mail.empresa.example` e corresponde a 192.0.2.20. 192.0.2.30 não é autorizado automaticamente: fail. Para incluí-lo: `v=spf1 a mx ip4:192.0.2.30 -all`.

Lab 4

198.51.100.10: include externo pass → pass principal. 192.0.2.10: include externo fail → não corresponde; o ip4 seguinte corresponde → pass. 203.0.113.40: include externo fail, ip4 não corresponde, `-all` principal → fail.

Lab 5

192.0.2.10 = pass local; 198.51.100.10 = pass na política redirecionada; 203.0.113.10 = fail redirecionado. O redirect devolve a conclusão da política de destino; o include usa o pass externo apenas como condição de correspondência.

Lab 6

Dois registros `v=spf1` no mesmo nome geram permerror. Consolide em um único TXT, por exemplo `v=spf1 ip4:192.0.2.10 include:_spf.vendor.example -all`, após confirmar que o fornecedor publica a política esperada.

Lab 7

O SPF Pass de `fornecedor.example` não alinha com `empresa.example` (domínios organizacionais diferentes). O DKIM Pass com `d=empresa.example` está alinhado; portanto o DMARC passa via DKIM.

Lab 8

Temperror por falha DNS (SERVFAIL), com ação temporária 451. Não há prova de ausência de autorização do IP. Investigue DNS autoritativo e recursivo, resolução e horário antes de qualquer alteração no SPF.

Lab 9

Política A (aspf omitido = relaxed): `mkt.empresa.example` e `empresa.example` compartilham o domínio organizacional; SPF alinhado → DMARC Pass. Política B (`aspf=s`): SPF não alinha; o DKIM com `d=plataforma.example` também não; DMARC Fail e, com `p=reject`, a mensagem tende a ser rejeitada. Para resistir ao strict, o fornecedor deve assinar DKIM com `d=empresa.example` (e configurar `adkim` compatível) ou usar MAIL FROM exatamente igual ao domínio do From.

Lab 10

SPF = fail (nenhum IP autorizado; confirmado no laboratório, teste "SEM ENVIO"). A política atual **não** protege o From visível: sem DMARC, o receptor não tem instrução para rejeitar uma mensagem cujo From alegue o domínio, especialmente se o MAIL FROM usar outro domínio. Falta publicar `_dmarc` com `p=reject` (e `sp`/`np`), Null MX se o domínio não recebe e, opcionalmente, o seletor DKIM revogado.

Lab 11

Identidade MAIL FROM (`identity=mailfrom`, domínio `empresa.example`). O cabeçalho foi gerado pelo pySPF, que descreve o erro no comentário ("Too many DNS lookups") e não emite o campo `problem=`; também não há `mechanism=`, porque nenhum termo encerrou a avaliação. O cabeçalho **não** diz se o IP está autorizado: o permerror por excesso de consultas interrompeu a avaliação antes de uma conclusão. Fluxos cujos IPs casam com termos do início da política podem passar antes de esgotar o orçamento, por isso o problema parece intermitente (capítulo 25.1). Primeiro passo: contar os termos no pior caso, expandindo os includes (capítulos 7.3 e 22), e só então reorganizar a política.

Lab 12

As mensagens passaram por uma lista de discussão: a lista reenviou de seu próprio IP preservando o envelope (SPF fail) e alterou a mensagem, quebrando a assinatura original (DKIM de `empresa.example` fail), e assinou com o próprio domínio (`lista.example`, não alinhado). O DMARC falhou, mas o receptor aplicou uma exceção local registrada como `mailing_list`, possivelmente com base em ARC (capítulo 11), e entregou. **Não** se deve autorizar o IP da lista no SPF da empresa: o fluxo não é da empresa e a exceção já é decidida pelo receptor.

C Referência rápida de investigação

Se encontrar...	Verifique primeiro...
spf=fail	IP efetivo, MAIL FROM, ordem dos mecanismos, IP omitido, encaminhamento.
spf=softfail	Qualificador `~all`; não confundir com pass.
spf=none	Nome DNS avaliado, TXT, NXDOMAIN e identidade HELO/MAIL FROM.
spf=temperror	Timeout, SERVFAIL, instabilidade DNS, momento da consulta.
spf=permerror	Sintaxe, duplicidade, include sem SPF, redirect, limite de 10 e void lookups; descrição do erro no Received-SPF (campo `problem=` ou comentário).
Permerror só para alguns IPs	Orçamento estourado no pior caso; contar termos com IP não autorizado (capítulo 25).
SPF pass / DMARC fail	Domínio do MAIL FROM versus From; modo `aspf`; DKIM alinhado.
Pass em relaxed, fail em strict	MAIL FROM em subdomínio; tag `aspf=s` recente.
Pass em IPv4 / fail em IPv6	Rota de saída, IP efetivo e mecanismo `ip6`.
Falha após encaminhamento	IP do intermediário, MAIL FROM preservado, SRS, cadeia ARC.
Spoofing de domínio inativo	SPF `-all`, DMARC `p=reject`, Null MX (capítulo 12).
Fonte desconhecida no relatório	Bruto versus alinhado; reason/type; reconhecimento interno do IP (capítulo 26).

Checklist final de cinco perguntas

01 Qual IP estabeleceu a conexão SMTP recebida?

02 Qual identidade SPF foi testada: MAIL FROM ou HELO/EHLO?

03 Qual registro TXT SPF único foi encontrado no nome correto?

04 Qual mecanismo encerrou o algoritmo e quais consultas adicionais ocorreram?

05 Qual foi o resultado SPF e qual foi, separadamente, a ação do destinatário?

D Fontes oficiais e leitura dirigida

As regras normativas foram fundamentadas nas publicações da IETF/RFC Editor e na documentação oficial dos projetos citados. Consulte o texto das RFCs para comportamentos de borda e para a diferença entre MUST, SHOULD e MAY.

[1] RFC 7208 — Sender Policy Framework (SPF), Version 1
`https://www.rfc-editor.org/rfc/rfc7208.html`
Seções 2 a 9; 3.3, 3.4, 4.6, 4.6.4, 5.2, 5.4, 5.7, 7 e 9.1: TXT, tamanho, avaliação, limites, mecanismos, macros e Received-SPF.

[2] RFC 9989 — Domain-Based Message Authentication, Reporting, and Conformance (DMARC)
`https://datatracker.ietf.org/doc/rfc9989/`
Proposed Standard, maio de 2026. Torna obsoletas as RFC 7489 e 9091. Alinhamento, tags aspf/adkim/np/psd/t e DNS Tree Walk.

[3] RFC 9990 e RFC 9991 — Relatórios DMARC agregados e de falha
`https://www.rfc-editor.org/rfc/rfc9990`
Formato XML, namespace dmarc-2.0, nomes de arquivo e verificação de destino externo; base dos capítulos 12 e 26.

[4] RFC 7489 — DMARC (histórica)
`https://www.rfc-editor.org/rfc/rfc7489.html`
Referência das revisões anteriores; útil para entender implementações que ainda usam a Public Suffix List.

[5] RFC 8601 — Message Header Field for Indicating Message Authentication Status
`https://www.rfc-editor.org/rfc/rfc8601.html`
Seções 1.2, 4, 5 e 7: fronteira de confiança, inserção e interpretação de Authentication-Results.

[6] RFC 8617 — Authenticated Received Chain (ARC)
`https://www.rfc-editor.org/rfc/rfc8617.html`
Categoria Experimental. Conjuntos AAR/AMS/AS, instâncias e validação da cadeia.

[7] RFC 7505 — A "Null MX" No Service Resource Record
`https://www.rfc-editor.org/rfc/rfc7505.html`
Registro `MX 0 .` para domínios que não recebem e-mail.

[8] RFC 5321 — Simple Mail Transfer Protocol
`https://www.rfc-editor.org/rfc/rfc5321.html`
MAIL FROM, RCPT TO, DATA e códigos de resposta SMTP.

[9] ISC BIND — páginas de manual (dig)
`https://bind9.readthedocs.io/en/stable/manpages.html`
Opções +stats, +comments, +norecurse e consulta a servidor específico.

[10] pySPF — projeto e API
`https://github.com/sdgathman/pyspf`
check2 e adaptador DNSLookup; versão 2.0.14 usada no laboratório.

[11] defusedxml — processamento seguro de XML em Python
`https://pypi.org/project/defusedxml/`
Usado pelo script do capítulo 26 para ler XML de terceiros.

[12] Postfix — controle de acesso SMTP e delegação de políticas
`https://www.postfix.org/SMTPD_ACCESS_README.html`
`https://www.postfix.org/SMTPD_POLICY_README.html`
Restrições, decisões de aceite/rejeição e integração com serviços de política.

> **OBSERVAÇÃO EDITORIAL** Políticas locais de gateways, versões de MTA e serviços externos podem produzir comportamentos próprios. As RFCs determinam a semântica; confirme separadamente a configuração implantada no seu ambiente.

E Registro de revisões

Revisão 4 — 28 de outubro de 2026

- Nova seção 8.3 (Received-SPF), com exemplos gerados pelo pySPF; campo correspondente no modelo de relatório.
- Novo capítulo 25 (estratégias para o limite de 10) e novo capítulo 26 (relatórios DMARC agregados, RFC 9990) com o script `dmarc_resumo.py`.
- Novos Labs 11 e 12 com gabarito; laboratório pySPF ampliado para dez testes (SUBDOMINIO e CABECALHO).
- Remissões aos novos capítulos nos capítulos 7, 12 e 13 e no Apêndice C.

Revisão 3 — 28 de outubro de 2026

- Novos capítulos: 9 (alinhamento relaxed/strict), 11 (SRS e ARC) e 12 (domínios que não enviam e-mail).
- Base DMARC atualizada para a RFC 9989; RFC 7489 mantida como referência histórica. Fontes consolidadas em um único apêndice.
- Tabela 8.2 refeita (estava desalinhada); fluxo do capítulo 2 redesenhado; comando `dig +stats` reposicionado no capítulo 3; frase do modelo de relatório que estava partida entre páginas reunida.
- Mecanismos `a` e `mx`: esclarecido que consultam A *ou* AAAA conforme a versão do IP da conexão.
- Novos Caso G e Labs 9 e 10, com gabarito; Caso D e Lab 7 ajustados para o conceito de domínio organizacional.
- Laboratório pySPF ampliado para oito testes (novo teste "SEM ENVIO"); nota sobre o `SyntaxWarning` no Python 3.12+.
- Apêndices passam a ser identificados por letra; sumário com paginação gerada automaticamente.

Revisão 2 — 28 de outubro de 2026

- Correções no comando de coleta DNS, na definição de consultas vazias, na tabela de alinhamento, no texto de anonimização, no diagrama e nos rodapés; ampliação da prática de investigação.

O que foi verificado nesta revisão

Executados os dez testes do laboratório pySPF 2.0.14 em Python 3.13: dois antes da mudança, quatro depois, um de domínio sem envio, dois de subdomínio de envio e um de excesso de includes, além da geração do Received-SPF. O script `dmarc_resumo.py` foi executado sobre dois relatórios fictícios (RFC 9990 em gzip e formato legado em zip). As saídas impressas nos capítulos 8.3, 20 e 26 vieram dessas execuções. As saídas de DNS, cabeçalhos e incidente são construções didáticas, não evidências de produção.